BaaS PME

Cobrar, movimentar, antecipar — e explicar cada centavo

Cairê Belo · Pedro Campanha
Bootcamp QI Tech · 10/10/2026

Um serviço financeiro modular: rigor matemático, confirmação transacional e história verificável.

Garantias verificadas e limitações conhecidas, não uma certificação de produção ou “100% seguro”.

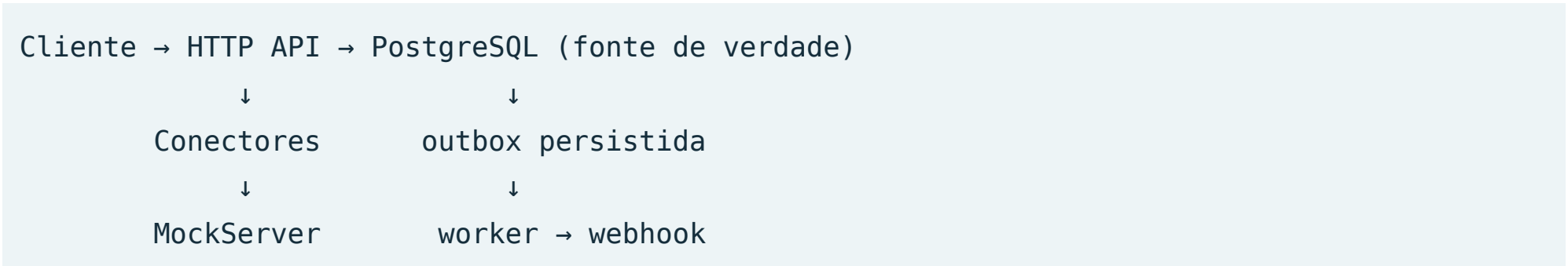
Escopo: S1–S21, Rodada 5 e líquido positivo (subparte autorizada P0.4). Restante do backlog 9.5 não implementado.

1. A história da PME

1. A PME emite um plano de cobrança: 12 boletos para seus pagadores.
2. Pode reajustar o segundo lote com IPCA/IGPM e consultar cada recebível.
3. Seleciona recebíveis próprios para antecipar liquidez, uma única vez.
4. Transfere, saca e reconstrói seu saldo pelo extrato.
5. Acompanha estado, atores, condições aplicadas e notificações.

Dois fluxos: cobrança cria recebível; antecipação consome esse recebível como lastro. Não há empréstimo, amortização ou baixa automática do pagador.

2. As peças e suas responsabilidades



Middleware → Schema → Resource → Controller → Repository → Model/DTO.

Controller coordena negócio e commit; conectores isolam I/O. UUIDs públicos, IDs internos para vínculos e ordem das travas.

Serviço modular + worker, banco/código compartilhados; não uma frota de microserviços. Exceções atuais: preço/risco em repositories e SQL no gravador de auditoria. Não há API Gateway.

3. Principal desafio: dinheiro sob disputa

20000 centavos iniciais. Quarenta transferências cruzadas de 100, com tarifa de 100, devem deixar **16000**, sem débito duplicado.

1. Travar contas por **ID interno crescente**, nunca por IP.
2. Reler saldo/estado depois da espera; validar principal + tarifa.
3. Confirmar saldos, ledger, snapshots, consumo, auditoria e resposta juntos.

Sem ordem: A segura A/espera B; B segura B/espera A. Com ordem, ambas disputam o menor ID primeiro.

Uma sequência possível (IDs internos ilustrativos):

```
A→B: lock #10 → lock #20 → validar → commit
B→A: espera #10 ————————→ lock #10 → lock #20 → validar → commit
```

FOR NO KEY UPDATE evita incompatibilidade com KEY SHARE da FK idempotente. Não promete eliminar todo deadlock possível; há recuperação limitada para falhas transitórias.

4. Resposta perdida não pode virar débito duplicado

`Idempotency-Key` + SHA-256 canônico + UNIQUE(conta, escopo, chave) + resposta confirmada.

- Mesmo corpo: 201 original e `Idempotent-Replayed: true`, sem novo lançamento.
- Corpo diferente: 409; falha desfaz a reserva e os efeitos.
- Retry de **toda a transação**, nova sessão: só 40P01/40001, até duas tentativas totais por padrão.
- Saldo insuficiente é 422 imediato. Não se retenta esperando outra transferência trazer dinheiro.

Transações e antecipações têm replay persistido. Emissão externa não tem essa garantia: rollback SQL não cancela boleto no provedor. Timeout/retentativa não é exatamente-once distribuído.

5. Personalização explicável, sem reescrever história

- Preço: PME específica > padrão; fixo em centavos + percentual em pontos-base; half-up.
- Risco: produtos habilitados, teto por operação, teto diário e quantidade de lastro.
- Snapshots registram política/versão/base/valor aplicado; nova versão não altera fatos passados.
- Quote de 60 segundos é prévia, sem reserva nem garantia de preço na confirmação.
- Maker-checker: OWNER propõe, outro OWNER aprova; pendência não vale na operação.

Políticas diretas contornam quatro olhos. Líquido positivo implementado: antecipação/cotação CREDIT_ADVANCE retornam 422/QIT001030 se tarifa ≥ bruto; execução valida antes do snapshot de preço. Bruto R$100/tarifa R$120 recusa mesmo com saldo anterior, sem consumir saldo/lastro. Replay preservado; CHECKs sem reescrita de legado.

6. Identidade e história verificável

- Bcrypt; acesso JWT de 15 minutos; refresh rotativo com sessão máxima de 8 horas; múltiplos dispositivos e revogação individual.
- JWT presente valida PME/papel: VIEWER consulta/cota; OPERATOR movimenta; OWNER altera estado.
- Status preserva eventos; auditoria SHA-256 encadeada correlaciona ator, recurso e request_id.
- Outbox confirma com block/cancel; worker entrega webhook com event_key para deduplicação.

Token interno é amplo; JWT opcional nas contas e bootstrap técnico sem RBAC próprio. Só audit_event bloqueia UPDATE/DELETE no SQL; administrador não é fronteira protegida. Checkpoint não é blockchain nem assinatura externa. Webhook é at-least-once.

7. Como provamos: testes e pipelines

```
push / PR → Compose + compilação → guardas
          → pytest cria ambiente descartável
          → HTTP + contratos SQL / locks / worker
          → JUnit + métricas + cleanup da sessão
```

Jornada real: quatro olhos → cobrança/reajuste → cotação/antecipação → transferência/saque → extrato → block/cancel/auditoria.

Concorrência: saldo, transferências cruzadas, mesma chave, limite e lastro. Relógio fixo: dia/noite, 20h/6h e replay entre janelas; não depende da hora do avaliador.

Falhas: rollback, conector, autorização, retry, líquido não positivo e erro sanitizado. Bootstrap Docker não é prova HTTP; testes não importam src. Red/Green só quando registrado. Resultados em COBERTURA/ENTREGA; CI remoto confirmado em 1603118, revisão nova exige novo CI. Aceite humano pendente.

8. Operação medida, não prometida

- Logs JSON normais com X-Request-ID; identificadores mascarados, sem body.
- `/metrics` interno: HTTP/QIT, replay, conector, lock, retry, sessões e outbox.
- Benchmark: **5 × 40 transferências cruzadas**, 200 operações; snapshots de CPU/RAM via Docker.
- Connect/read 1s/5s, lock/statement 2s/10s, orçamento 15s: limites de esperas conhecidas.

Medir correção não é provar capacidade sustentável. Duração/recursos dependem do ambiente; não são SLO.

BENCHMARK documenta resultados/ambiente. Registry por processo; não há coletores/Alertmanager/cAdvisor instalados. Regras de alerta são propostas. Deadline rígido e sanitização universal de tracebacks não estão entregues.

9. Decisões e fechamento honesto

Decisão	Por que agora	Ganharia em outro cenário
Banco/serviço modular	ACID simples para dinheiro	Domínios/deploys independentes
Lock pessimista ordenado	Decisão sobre saldo protegido	Baixa contenção favorece otimista
Centavos inteiros	Contrato exato e previsível	Frações de centavo exigem outra representação
Eventos, não soft delete	História financeira preservada	Remoção de dados descartáveis

Entregue: produto, testes, contratos e evidências reproduzíveis.
Fora desta rodada: restante do hardening 9.5/P0.4 e produção/SLO/gateway.
Confirmação humana: revisão dos PDFs, ensaio e clone por outra pessoa.

Fontes: RFC/DECISOES (contratos), COBERTURA (testes), BENCHMARK (medição), ENTREGA (execução final). A banca recebe fatos verificáveis, não promessas absolutas.